

ISO 27001 Compliant Incident Management Report - SQL Injection Vulnerability

Introducción

Este informe detalla la identificación y explotación de una vulnerabilidad de inyección SQL en la aplicación web Damn Vulnerable (DVWA). La prueba se realizó en un entorno controlado para demostrar una vulnerabilidad común y su posible impacto en la seguridad de la aplicación.

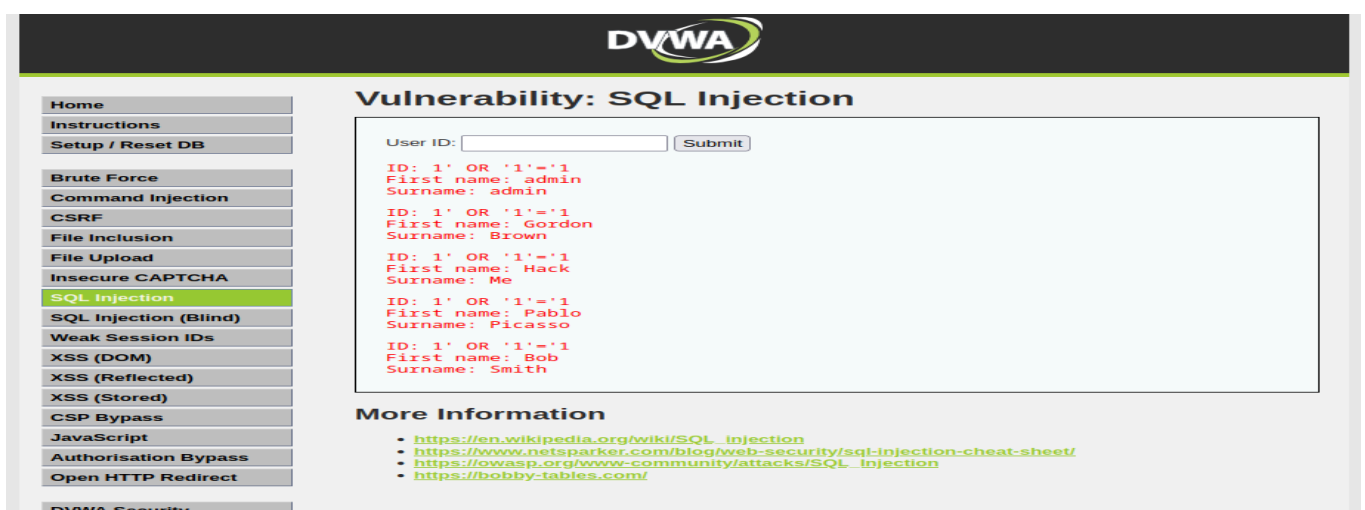
Descripción del Incidente

Durante la evaluación de seguridad de DVWA, se descubrió una vulnerabilidad de inyección SQL en el módulo "Inyección SQL". Esta vulnerabilidad permite a un atacante inyectar consultas SQL maliciosas a través del campo de entrada de la aplicación web.

Método Utilizado: SQL Injection

Pasos realizados:

1. Se accedió al formulario de inicio de sesión en la URL.
2. En el campo *Usuario* se ingresó el payload malicioso.
3. En el campo *Contraseña* se ingresó cualquier valor arbitrario.
4. Se presionó el botón de *Iniciar sesión*.
5. Resultado: el sistema permitió el acceso sin validar credenciales reales, redirigiendo al panel del usuario autenticado.



Impacto del Incidente

La vulnerabilidad permite a un atacante:

- Bypassear el sistema de autenticación.
- Acceder a información sensible como datos personales, credenciales y registros de usuarios.
- Modificar o eliminar información en la base de datos si la cuenta del sistema tiene permisos elevados.
- Escalar privilegios en el sistema si hay otras configuraciones inseguras.
- Comprometer la integridad y disponibilidad del servicio web.

Nivel de criticidad: **Alta**

Recomendaciones

Para mitigar esta vulnerabilidad, se recomienda:

- **Implementar consultas parametrizadas** en lugar de concatenar directamente los valores ingresados por el usuario.
- **Validar y sanear todas las entradas del usuario**, incluso si provienen de formularios internos.
- **Limitar los permisos** de la cuenta de la base de datos utilizada por la aplicación web.
- **Habilitar un firewall de aplicaciones web (WAF)** para detectar y bloquear patrones de inyección SQL conocidos.
- **Realizar pruebas de penetración** periódicas y escaneos automatizados de seguridad.
- **Registrar e investigar** cualquier intento de acceso anómalo.

Conclusiones

La aplicación presenta una vulnerabilidad crítica de inyección SQL que compromete seriamente la seguridad del sistema y de los datos almacenados. Esta falla permite a un atacante evadir controles de autenticación y acceder a información confidencial. Es imperativo corregir esta vulnerabilidad de inmediato para evitar brechas de seguridad, pérdidas de datos y daños reputacionales.